

Actividad 1. Principios de Seguridad — Cumplimiento Total de Tareas (Saber 1 pts.)

En base al estudio de caso seleccionado por el equipo (Leños Rellenos o Gestión de Proyectos PAEC), el docente evaluará el cumplimiento de una aplicación web Progressive Web App (PWA), construida a partir de los requerimientos funcionales y no funcionales descritos en el caso correspondiente, que se apegue a los estándares de seguridad establecidos por la Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados, con el fin de identificar vulnerabilidades, mitigar riesgos y garantizar la protección de los datos personales de los usuarios (clientes, integrantes de equipo, según el caso).

Lista de Cotejo FrontEnd

Criterios de principios de Protección de datos	Cumple
Aviso de Privacidad Integral y Simplificado: debe estar visible, disponible y de fácil acceso antes de que el usuario introduzca cualquier dato personal (datos de entrega en Leños Rellenos; datos de integrantes/avance en Gestión de Proyectos). Si hay capturas en diferentes secciones, incluir enlace directo al aviso.	☐
Seguridad en el Navegador y Transporte: uso estricto de HTTPS (TLS 1.3 recomendado); cookies seguras (Secure, HttpOnly, SameSite) si almacenan tokens de sesión.	☐
Validación de Datos en Cliente: evitar enviar al BackEnd más datos de los estrictamente necesarios (principio de proporcionalidad y minimización).	☐

Lista de cotejo BackEnd

Criterios de Seguridad de los Datos	Cumple
Ciclo de Vida y Minimización de Datos: solo solicitar/almacenar los datos estrictamente necesarios; procesos automáticos de borrado o anonimización una vez cumplida la finalidad.	☐
Cifrado en reposo: bases de datos y archivos de configuración con datos personales deben estar cifrados.	☐
Control de accesos estricto (RBAC): solo roles autorizados pueden leer o modificar datos personales.	☐
Hashing de contraseñas: uso de algoritmos robustos (bcrypt o Argon2).	☐
Lógica de Acceso, Rectificación, Cancelación y Oposición (ARCO): el sistema debe poder bloquear y posteriormente eliminar/anonimizar datos a solicitud del usuario, sin romper la integridad de la base de datos.	☐

Trazabilidad y Bitácoras (Logs) de Auditoría: registro de quién, cuándo y para qué se accedió a los datos, sin escribir datos personales directamente en los logs.	☐
Transferencias de Datos: si el BackEnd se conecta con APIs de terceros (p. ej. WhatsApp API en Leños Rellenos, o servicios de notificación/calendario en Gestión de Proyectos), estas deben estar consentidas por el usuario y viajar por canales cifrados (mTLS o tokens seguros).	☐

Nota: cada criterio tiene un valor de 0.1 puntos. Se deberá evidenciar ante el docente el cumplimiento de cada criterio. Elaborar un reporte con el nombre "Unidad3 Instrumento de Evaluación R1.pdf", indicando en la portada el estudio de caso trabajado, con entrega de la Actividad 1 a más tardar en la fecha indicada por el facilitador en la plataforma E-learning UTNG. En caso de atraso, la actividad tendrá un valor del 50%.

Actividad 2. Lista de criterios OWASP Top 10 — Cumplimiento Total de Tareas Saber Hacer (1.0 pts)

En base al estudio de caso seleccionado por el equipo, el docente evaluará el cumplimiento de la aplicación web PWA desarrollada con los estándares de seguridad del OWASP Top 10, con el fin de identificar vulnerabilidades, mitigar riesgos y garantizar la protección de los datos personales de los usuarios.

Nota:

Para ambos casos: adapta los ejemplos de endpoint a las entidades de tu propio caso. Por ejemplo, /api/v1/pedido/105 para Leños Rellenos, o /api/v1/equipo/105 y /api/v1/historia/105 para Gestión de Proyectos PAEC.

Lista de Cotejo FrontEnd

Criterio de Evaluación	Cumple
Pruebas de XSS (Cross-Site Scripting) — 0.2 pts. Inserta scripts maliciosos en los formularios de captura (datos de entrega, comentarios de dailies, etc.) y verifica sanitización.	☐
Seguridad de las Cookies y Almacenamiento Local — 0.1 pts. Verificar atributos Secure, HttpOnly y SameSite=Strict, o riesgos de localStorage.	☐
Inyección de Contenido y Clickjacking — 0.1 pts. Evaluar si la app puede embeberse en un iframe malicioso; configurar X-Frame-Options o CSP.	☐
Desmitificar la "Seguridad" del FrontEnd — 0.1 pts. Intentar saltar validaciones de campos desde herramientas de desarrollador (F12) y verificar que el BackEnd las revalide.	☐

Lista de cotejo BackEnd

Criterio de Evaluación	Cumple
Pruebas de BOLA (Broken Object Level Authorization) — 0.1 pts. Cambiar un ID en la petición (pedido, equipo, historia de usuario) para intentar acceder a datos de otro usuario/equipo sin autorización.	☐
Pruebas de Inyección (SQLi, NoSQLi) — 0.1 pts. Enviar caracteres especiales (' , " , OR 1=1) en filtros o búsquedas de la API.	☐
Fuga de Datos Masiva (Mass Assignment / Excessive Data Exposure) — 0.1 pts. Revisar que las respuestas JSON no expongan contraseñas hash u otros datos sensibles innecesarios.	☐
Falta de Rate Limiting — 0.2 pts. Verificar bloqueo tras múltiples peticiones automatizadas al login o endpoints de consulta.	☐

Herramientas sugeridas: OWASP ZAP o Burp Suite (interceptar tráfico), Postman + Newman (automatizar pruebas de endpoints), SonarQube o Semgrep (análisis estático de código), OWASP Dependency-Check / Snyk (vulnerabilidades en librerías de terceros).

Agregar el respectivo reporte a "Unidad3 Instrumento de Evaluación R1.pdf", sección Actividad 2. En caso de atraso, la actividad tendrá un valor del 50%.

Actividad 3. Desarrollo Web Seguro — Procedimiento (Saber 1.0 pts – Saber Hacer 4.0 pts)

Objetivo de la Actividad

Diseñar, codificar y desplegar una aplicación web con arquitectura desacoplada (FrontEnd y BackEnd) utilizando metodologías ágiles, patrones de diseño y un flujo de trabajo moderno basado en Git, automatización (CI/CD) y contenedores. El proyecto deberá priorizar la seguridad, la robustez arquitectónica y el cumplimiento normativo en el manejo de datos.

Descripción del Escenario

Cada equipo (2 a 3 integrantes) desarrollará la aplicación web correspondiente a su estudio de caso seleccionado:

- ✓ **Leños Rellenos:** sistema de catálogo digital, carrito de compras, generación automática de pedido con redirección a WhatsApp, y panel de administración con gestión de productos, control de stock y estado de pedidos — conforme a los requerimientos funcionales (RF1–RF7) y no funcionales (RNF1–RNF5) descritos en el documento de caso.
- ✓ **Gestión de Proyectos PAEC:** sistema web/móvil para el registro de proyectos, equipos y roles; planeación por sprint (nombre de actividad, descripción, criterios de aceptación, integrantes, fechas, estimación, prioridad y parcial); seguimiento del Design Sprint (mapear, bocetar, decidir, prototipar, probar); tablero Kanban con aprobación del Scrum Master; registro de dailies; alertas automáticas de retraso; y reportes de avance (histograma por equipo, esfuerzo por integrante, puntos de historia, diagrama de Gantt, story points completados vs. planificados) — conforme al procedimiento descrito en el documento de caso.

En ambos casos, el sistema debe ser capaz de consumir datos externos, exponer sus propias funcionalidades y ejecutarse de manera idéntica tanto en las computadoras del equipo como en la nube.

Requerimientos Técnicos del Proyecto

Los equipos deberán entregar una solución que cumpla estrictamente con los siguientes componentes:

Metodología Ágil y Control de Versiones

- ✓ Gestión del Proyecto: uso de GitHub Projects para gestionar el backlog, sprints e historias de usuario.
- ✓ Estrategia de Ramas: implementar GitFlow (ramas para main, develop y feature/*).
- ✓ Colaboración Profesional: prohibido hacer push directo a main o develop. Cada cambio debe integrarse mediante un Pull Request (PR) aprobado por al menos otro integrante del equipo y las pruebas automatizadas.

Arquitectura de Software y Patrones de Diseño

- ✓ Arquitectura desacoplada (FrontEnd independiente del BackEnd, comunicación estrictamente en JSON).
- ✓ Al menos cinco patrones de diseño explícitos en el BackEnd (ej. Repository, Factory, Singleton para conexión a BD, Dependency Injection), documentados en el código.

DevOps, Contenedores y Automatización (CI/CD)

- ✓ Dockerfile propio y optimizado para BackEnd y para FrontEnd; docker-compose.yml que levante el entorno completo (App + Base de Datos) con un solo comando.
- ✓ GitHub Actions: workflow disparado en cada PR hacia develop o main que instale dependencias, ejecute linters y corra la suite de pruebas unitarias.
- ✓ Despliegue Automático (CD): al fusionar un PR en main, un webhook o acción de GitHub debe compilar y desplegar automáticamente en un proveedor de nube (Render, Railway, AWS, Azure o GCP).

Conectividad (Web Services)

- ✓ Web Services Propios: API RESTful documentada con métodos HTTP correctos (GET, POST, PUT, DELETE) y códigos de estado adecuados (200, 201, 400, 401, 403, 500).
- ✓ Web Services de Terceros: la aplicación debe consumir al menos una API externa. Sugerencia por caso: Leños Rellenos puede usar la API de WhatsApp Click-to-Chat (ya contemplada en el caso) o una API de mapas para ubicar entregas; Gestión de Proyectos PAEC puede integrar una API de notificaciones o de calendario para alertar al Scrum Master sobre retrasos.

Mecanismos de Seguridad y Privacidad

- ✓ Autenticación y Autorización: control de accesos basado en roles (RBAC) mediante tokens seguros (JWT) — por ejemplo, Cliente/Administrador en Leños Rellenos, o Estudiante/Scrum Master/Docente en Gestión de Proyectos PAEC.
- ✓ Seguridad en el Transporte: el despliegue en la nube debe contar obligatoriamente con HTTPS activo.
- ✓ Validación de Datos: el BackEnd debe sanitizar y validar todos los datos entrantes (evitando inyecciones SQL y ataques XSS). Las validaciones del FrontEnd no sustituyen a las del BackEnd.
- ✓ Cumplimiento Normativo (LGPDPPSO / RGPD): enlace visible al Aviso de Privacidad en el FrontEnd, e implementación de casillas de verificación no pre-marcadas para consentimiento explícito cuando se manejen datos sensibles.

Entregables obligatorios

- ✓ Enlace al repositorio de GitHub (público o con acceso compartido al docente); el historial de commits debe reflejar la participación de todos los integrantes.
- ✓ Enlace de la aplicación en funcionamiento (producción), URL pública (HTTPS) para evaluación en tiempo real.
- ✓ Archivo README.md profesional con: diagrama de arquitectura, instrucciones para ejecutar el proyecto localmente con docker-compose, evidencia (capturas) de ejecuciones exitosas de GitHub Actions, y lista de credenciales de prueba (usuarios con distintos roles).

Lista de Cotejo

#	Componente / Criterio a Evaluar	Valor	Sí/No
1	Gestión, Git y Metodología Ágil: uso de ramas (feature/*, develop, main); integración estrictamente mediante PRs aprobados por el equipo.	0.5 pts	☐
2	Arquitectura y Patrones de Diseño: separación total FrontEnd/BackEnd; al menos dos patrones de diseño documentados en código.	0.5 pts	☐
3	Dockerización: Dockerfile propio y optimizado; docker-compose.yml que levanta el entorno completo sin errores.	1.0 pts	☐
4	Automatización y Despliegue (CI/CD): pipeline en GitHub Actions con linters y pruebas ante cada PR; despliegue automático al fusionar en main.	1.0 pts	☐
5	Servicios Web Propios y de Terceros: API propia RESTful funcional; consumo exitoso de al menos un servicio de terceros.	0.5 pts	☐
6	Mecanismos de Seguridad y Privacidad: RBAC con JWT; HTTPS forzado en la nube; sanitización/validación de datos en el BackEnd.	0.5 pts	☐
7	Entregables y Repositorio en Funcionamiento: URL pública operando al 100%; README.md con diagrama, instrucciones y credenciales de prueba.	0.5 pts	☐
8	Uso de Inteligencia Artificial y cualquiera de las funcionales	0.5 pts	☐

Nota: se deberá evidenciar ante el facilitador el cumplimiento de cada criterio. Agregar el informe de la Actividad 3 al documento "Unidad3 Instrumento de Evaluación.pdf".

Actividad 4. Evaluación Teórica y Práctica (Saber – 2.0 puntos)

Evaluación teórica de identificación de conceptos de la unidad (Saber 2 pts) a través de la plataforma E-learning UTNG

Especificaciones del reporte final

- ✓ Portada: nombre y logo de la institución, carrera, grupo, unidad, nombre y número de control de cada integrante, rol desempeñado en el equipo, estudio de caso seleccionado, y fecha.
- ✓ Encabezado y pie de página; tipografía Arial 11, justificado; interlineado 1.15.
- ✓ Introducción (mínimo 200 palabras).
- ✓ Cuerpo del documento con las actividades desarrolladas de la 1 a la 3.
- ✓ Conclusión (100 palabras).
- ✓ Referencia bibliográfica estilo APA 7.

SER Saber-Hacer 10%

- ✓ Entregas parciales progresivas en asesoría vía agenda en SIGA, donde se deberá de tener al menos cuatro registros de asesoría para entrega de sus avances

NOTA: Período para la entrega es del 13 de julio al 5 de agosto

Bibliografía

OWASP. (2024). Source Code Analysis Tools. Obtenido de OWASP: https://owasp.org/www-community/Source_Code_Analysis_Tools

OWASP. (2024). Vulnerability Scanning Tools. Obtenido de OWASP: https://owasp.org/www-community/Vulnerability_Scanning_Tools

Wichers, D. (s.f.). Free for Open Source Application Security Tools. Obtenido de OWASP: https://owasp.org/www-community/Free_for_Open_Source_Application_Security_Tools